⚠️ 공급망 보안 긴급 경보

Axios NPM 패키지 악성코드 삽입 사고

Active Supply Chain Attack | 심각도: **CRITICAL**

Dennis Kim / gameworker@gmail.com / https://github.com/gameworkerkim/

1. 개요 (Executive Summary)

[긴급] 2026년 3월 31일, JavaScript 생태계의 핵심 HTTP 클라이언트 라이브러리인 Axios의 npm 패키지가 정식 레지스트리를 통해 악성코드를 포함한 의존성 패키지와 함께 배포되는 공급망 공격이 확인되었습니다. 주간 다운로드 수 약 8,300만 건에 달하는 Axios의 특성상 폭발적 피해 범위가 우려됩니다.

이번 공격은 공식 GitHub 리포지토리의 릴리스 태그를 우회하여 npm 레지스트리에 직접 악성 버전을 게시하는 방식으로 이루어졌습니다. 타협된 버전들은 악성 패키지인 plain-crypto-js@4.2.1을 트랜지티브(transitive) 의존성으로 자동 설치하도록 설계되었으며, Socket의 자동 악성코드 탐지 시스템에 의해 최초 발견되었습니다.

2. 침해 패키지 현황

패키지명	버전	역할	상태
`axios`	1.14.1	HTTP 클라이언트 라이브러리	감염됨
`axios`	0.30.4	HTTP 클라이언트 라이브러리	감염됨
`plain-crypto-js`	4.2.1	트랜지티브 악성 의존성	악성 페이로드

⚠️ **안전한 버전: Axios 1.14.0 (GitHub 태그에 정상적으로 존재하는 최신 안전 버전)**

3. 공격 타임라인

시각 (UTC)	이벤트
3월 30일 23:59:12	**악성 패키지 plain-crypto-js@4.2.1 npm 레지스트리에 게시**
3월 31일 00:00 직후	침해된 Axios v1.14.1 및 v0.30.4 npm에 즉시 게시
3월 31일 00:05:41	**Socket 자동 악성코드 탐지 시스템에 의해 이상 패키지 플래그 처리**
3월 31일 오전 (진행 중)	보안 연구원 및 다운스트림 팀 사고 대응 착수

[분석] 공격자는 탐지를 최소화하기 위해 악성 패키지 게시 직후 수 분 이내에 침해된 Axios 버전을 연속 게시하는 속전속결 전략을 구사했습니다. 이는 보안 도구의 스캔 주기를 노린 정교한 타이밍 공격입니다.

4. 공격 기법 분석 (TTPs)

4.1 GitHub-npm 릴리스 파이프라인 우회

정상적인 Axios 릴리스는 GitHub에 태그를 생성한 뒤 npm에 게시되는 표준 절차를 따릅니다. 그러나 이번 침해 버전들(v1.14.1, v0.30.4)은 GitHub 태그에 존재하지 않으며, 이는 공격자가 정상 배포 파이프라인을 완전히 우회하여 npm 레지스트리에 직접 게시했음을 의미합니다.

이 수법은 개발자들이 GitHub 태그를 신뢰의 기준점으로 삼는다는 점을 악용합니다. GitHub 릴리스 페이지만 확인하고 npm 버전을 별도로 검증하지 않을 경우, 악성 버전이 자동으로 설치될 수 있습니다.

4.2 최소 수정 전략 (Minimal Diff Attack)

공격자는 Axios 핵심 코드베이스를 거의 수정하지 않았습니다. 유일한 변경은 의존성 트리에 plain-crypto-js@4.2.1을 추가한 것입니다. 이 전략은 대용량 코드 변경이 수반되는 코드리뷰 경보를 피하면서도, 트랜지티브 의존성을 통해 임의 코드를 실행할 수 있게 합니다.

4.3 계정 탈취 (Account Takeover)

npm 레지스트리 로그 분석 결과, 악성 패키지는 jasonsaayman 계정으로 게시된 것으로 확인됩니다. 이는 다음 중 하나의 경로로 공격이 이루어졌음을 시사합니다:

- Axios 메인테이너 계정 크리덴셜 탈취
- npm 세션 토큰 하이재킹
- MFA 없는 계정에 대한 무차별 대입(Brute Force) 또는 피싱 공격

5. 영향 범위 및 위험 평가

항목	내용
주간 다운로드	약 83,000,000회 (npm 기준)
직접 영향 버전	axios@1.14.1, axios@0.30.4
악성 의존성	plain-crypto-js@4.2.1
적용 대상	프론트엔드, 백엔드 마이크로서비스, 엔터프라이즈 애플리케이션 전반
피해 가능성	악성코드의 성격에 따라 데이터 탈취, 임의 코드 실행 등 다양한 위협 상존
탐지 지연 위험	배포 후 약 6분 뒤 자동 탐지 → 그 사이 다운로드된 패키지는 이미 감염

6. 즉각 대응 조치 (Immediate Actions Required)

Step 1 피해 버전 탐지

프로젝트의 package-lock.json 또는 yarn.lock 파일에서 다음 버전 포함 여부를 즉시 확인합니다:

- axios@1.14.1
- axios@0.30.4
- plain-crypto-js@4.2.1 (트랜지티브 의존성으로 포함된 경우 포함)

Step 2 의존성 롤백

감염 버전이 확인될 경우, 즉시 알려진 안전 버전으로 롤백합니다:

> **권장 버전:** axios@1.14.0 (GitHub 태그에 존재하는 직전 안전 버전)

Step 3 의존성 그래프 감사

lockfile 및 의존성 그래프, 오픈 PR, 기능 브랜치 전체에 대한 확장 감사를 수행합니다. 특히 CI/CD 파이프라인에서 자동으로 설치되는 패키지를 중점 점검합니다.

Step 4 지속적 모니터링

사고가 현재 진행 중이므로, 위협 인텔리전스 피드 구독 및 추가 악성 버전 게시에 대한 실시간 알림 설정을 권고합니다.

7. 교훈 및 예방 전략

이번 사건은 오픈소스 공급망 보안의 구조적 취약점을 정면으로 드러냅니다. 다음의 예방 조치를 조직 차원에서 도입을 검토할 것을 권고합니다:

- npm publish 계정에 반드시 MFA(다중 인증) 활성화 — npm 은 인기 패키지에 MFA 를 의무화하고 있으나, 이번 사건은 그 적용의 중요성을 다시금 상기시킵니다.
- lockfile 기반 배포 강제화 — npm ci 사용을 통해 lockfile 에 명시된 버전만 설치하도록 파이프라인을 구성합니다.
- SCA(Software Composition Analysis) 도구 도입 — Socket, Snyk, Dependabot 등 자동화된 의존성 취약점 스캐너를 CI/CD 에 통합합니다.
- GitHub-npm 버전 교차 검증 — npm 의 패키지 버전이 GitHub 태그에 실제로 존재하는지 배포 전 자동 검증하는 스크립트를 도입합니다.
- 내부 npm 미러 또는 아티팩트 레지스트리 운영 — Nexus, Artifactory 등을 활용하여 검증된 패키지만 내부적으로 허용합니다.
- 의존성 변경 사항 코드리뷰 의무화 — package.json 및 lockfile 변경 시 추가 승인자 지정 및 자동 경보 설정을 권고합니다.

8. 결론

Axios npm 공급망 침해 사고는 단순한 개별 라이브러리 사건을 넘어, 현대 소프트웨어 생태계가 직면한 공급망 보안 위기의 단면을 보여주는 사례입니다. 주간 8,300만 다운로드라는 규모가 증명하듯, 단 하나의 핵심 패키지 타협만으로도 수십만 개 프로젝트에 동시 피해를 초래할 수 있습니다.

사고는 현재 진행 중(Active Incident)이므로, 개발팀 및 보안팀은 즉각적인 버전 확인과 롤백을 최우선으로 실행하고, 이후 공급망 보안 체계 전반을 점검하는 계기로 삼아야 합니다.

> **[출처]** CyberSecurityNews.com — Axios NPM Packages Compromised to Inject Malicious Codes in an Active Supply Chain Attack (2026.03.31)

https://x.com/The_Cyber_News/status/2038825730021437863